Introduction à la cybersécurité

Corrigé d'examen

Source : examen-2025-01-24-b.pdf · 20 questions

En-tête : 24 janvier 2025, série B.

Question 1 · A, B, C, F Dans le scénario du cours, l'attaquant recrute des machines compromises, choisit une cible et active ses machines. Leurs requêtes simultanées saturent le service.

Ch. 1, Disponibilité — exemple DDoS, p. 34 du PDF

Question 2 · A, C, E L'anti-malware bloque certaines charges, le marquage des expéditeurs inconnus alerte l'utilisateur et la MFA limite l'exploitation d'un mot de passe volé.

À noter : F est défendable si l'on parle d'un mécanisme concret d'authentification de l'origine du courrier, comme DKIM. La diapositive cite A, C et E ; une signature numérique générique ne détecte pas le phishing à elle seule.

Ch. 1, Exemple de menace : phishing, p. 20 du PDF ; ch. 4, MFA, p. 220–221

Question 3 · A, B, D Pour attribuer une action, il faut établir l'identité de son auteur et conserver une trace d'audit intègre. La non-répudiation évite qu'il puisse nier sa participation.

Ch. 1, Responsabilité et non-répudiation, p. 31 et 57–58 du PDF

Question 4 · A, D, E Le hachage se calcule rapidement mais une seconde préimage et une collision doivent être difficiles à trouver. Des collisions existent malgré cette résistance.

Ch. 2, Fonctions de hachage — caractéristiques et collisions, p. 97–101 du PDF

Question 5 · B, D, F, G, H Les participants génèrent deux paires, échangent les parties publiques et calculent chacun le même secret avec leur partie privée et la partie publique reçue. Une KDF dérive la clé de session de ce secret.

Ch. 3, Échange de clés Diffie-Hellman et KDF, p. 176–178 du PDF

Question 6 · F La rapidité est un avantage par rapport au chiffrement asymétrique, pas par rapport à lui-même comme l'indique C. Le chiffrement symétrique utilise un secret partagé pour les messages et ne résout pas seul sa distribution.

À noter : Si C voulait comparer au chiffrement asymétrique, cette option serait vraie. F suit le libellé imprimé.

Ch. 2, Chiffrement symétrique et problème d'échange, p. 119 et 153–158 du PDF

Question 7 · A, C Les algorithmes concernés attendent des blocs de taille fixe. Au besoin, le dernier bloc reçoit des bits de remplissage ; le schéma choisi indique comment les ajouter ou les retirer. Le chaînage et la parallélisation dépendent du mode de traitement.

À noter : Dans C, « arbitraires » peut désigner des bits ajoutés au message, mais ne signifie pas qu'on peut ignorer la règle du schéma de padding.

Ch. 2, Padding et chiffrement par blocs, p. 80–88 et 125 du PDF

Question 8 · A, B, E La PKI facilite la diffusion des certificats et l'association clé publique–titulaire. Une clé privée compromise justifie une révocation avant expiration ; un certificat périmé cesse déjà d'être valide.

Ch. 3, Certificats et PKI ; révocation, p. 181–185 et 196 du PDF

Question 9 · A, B, C, E, F La validation remonte les signatures des autorités intermédiaires jusqu'à une ancre racine reconnue. Une chaîne valide établit alors le lien attesté entre la clé publique et son titulaire.

Ch. 3, Certificats et chaîne de confiance, p. 181–183 et 201–205 du PDF

Question 10 · A, C, D, E Il faut un émetteur dont la chaîne est reconnue, une période de validité en cours, une signature valide et un certificat non révoqué. Une interception peut présenter un faux certificat sans rendre invalide le certificat légitime.

Ch. 3, Certificats X.509, révocation et chaîne de confiance, p. 185, 196–197 et 201–205 du PDF

Question 11 · B Le contrôle d'accès décide quelles actions un utilisateur identifié peut effectuer et sur quelles ressources.

Ch. 1, Objectifs AAA, p. 31 du PDF ; ch. 4, Contrôle d'accès, p. 310

Question 12 · C La séparation des devoirs distribue les rôles et responsabilités pour éviter les conflits d'intérêts. Restreindre les droits d'administration relève surtout du moindre privilège.

Ch. 4, Contrôle d'accès — principes, p. 311 du PDF

Question 13 · A, C, E On privilégie la longueur, un gestionnaire et l'absence d'informations personnelles faciles à deviner. La réutilisation et la rotation périodique systématique sont à éviter.

Ch. 4, Mots de passe — bonnes pratiques, p. 237 et 246–247 du PDF

Question 14 · A, B, C Les catégories classiques sont la connaissance, la possession et l'inhérence. La MFA combine plusieurs facteurs distincts.

Ch. 4, Credentials et MFA, p. 218–220 du PDF

Question 15 · A, B, C, D Dans le flux présenté, le serveur émet un jeton signé après authentification. Le client le joint ensuite aux requêtes protégées sur TLS. Pour la variante asymétrique, la vérification utilise la clé publique du serveur signataire.

À noter : D s'applique au schéma asymétrique montré. Le cours décrit aussi la variante HMAC, qui se vérifie avec un secret partagé et non une clé publique.

Ch. 4, JWT — contenu, échange et validation, p. 316–319 et 321–327 du PDF

Question 16 · B, D Un jeton matériel doit être obtenu, acheté et remis ou enrôlé auprès de son utilisateur. Copier le secret et rejouer une réponse ne sont pas des défauts inhérents au matériel : cela dépend du mécanisme et de sa mise en œuvre.

À noter : E peut décrire certaines procédures de remise en personne. Le cours ne permet pas de dire que cela arrive souvent ; la distribution et l'enrôlement peuvent se faire à distance.

Ch. 4, Jetons matériels et mots de passe à usage unique, p. 291–295 et 329–331 du PDF

Question 17 · A, B, D Le client signe un défi frais avec sa clé privée ; le serveur vérifie avec la clé publique du client. La clé privée n'est pas révélée et une ancienne signature ne répond pas à un nouveau défi.

Ch. 4, Preuve sans divulgation et défi-réponse signé, p. 223, 259 et 263 du PDF

Question 18 · B, C, F Un WAF inspecte le contenu et les en-têtes applicatifs pour détecter, par exemple, des injections. Souvent placé à la terminaison TLS, il protège les applications exposées côté serveur et peut appliquer des règles d'accès.

Ch. 5, Pare-feu — pare-feu applicatifs et NGFW, p. 419–420 et 426 du PDF

Question 19 · A, D, E, F, G, H Une DMZ accueille des services exposés et leurs intermédiaires : terminaison TLS, proxy inverse, répartition de charge, pare-feu et routeurs. Les postes du personnel et les réseaux Wi-Fi ont d'autres segments.

À noter : Le dessin p. 449 inclut un routeur et des pare-feu dans la zone ou à sa frontière. Des serveurs web publics peuvent être en DMZ ; dans le schéma plus strict, le serveur applicatif reste derrière un proxy.

Ch. 5, segmentation et DMZ, PDF p. 425–426, 445 et 449

Question 20 · B En pratique, la zone parente publie un enregistrement DS qui contient un condensat de la clé de délégation KSK de l'enfant. DNSSEC signe les ensembles d'enregistrements, pas chaque message DNS.

À noter : A est défendable si « client » désigne le résolveur validant qui interroge les serveurs DNS ; ce n'est pas une obligation pour le poste final. Le schéma simplifié p. 489 est précisé p. 528 : le parent ne conserve pas la ZSK de l'enfant.

Ch. 5, DNSSEC — résolution et conclusions, p. 488–497 et 527–528 du PDF